Seguridad en K8S

CAS TRAINING

BUENAS PRACTICAS SEGURIDAD

- Deshabilitar el acceso root.
- Desactivar la autenticación basada en contraseñas.
- Forzar la autenticación mediante claves SSH.
- Implementar medidas adicionales para asegurar tus sistemas físicos o virtuales.

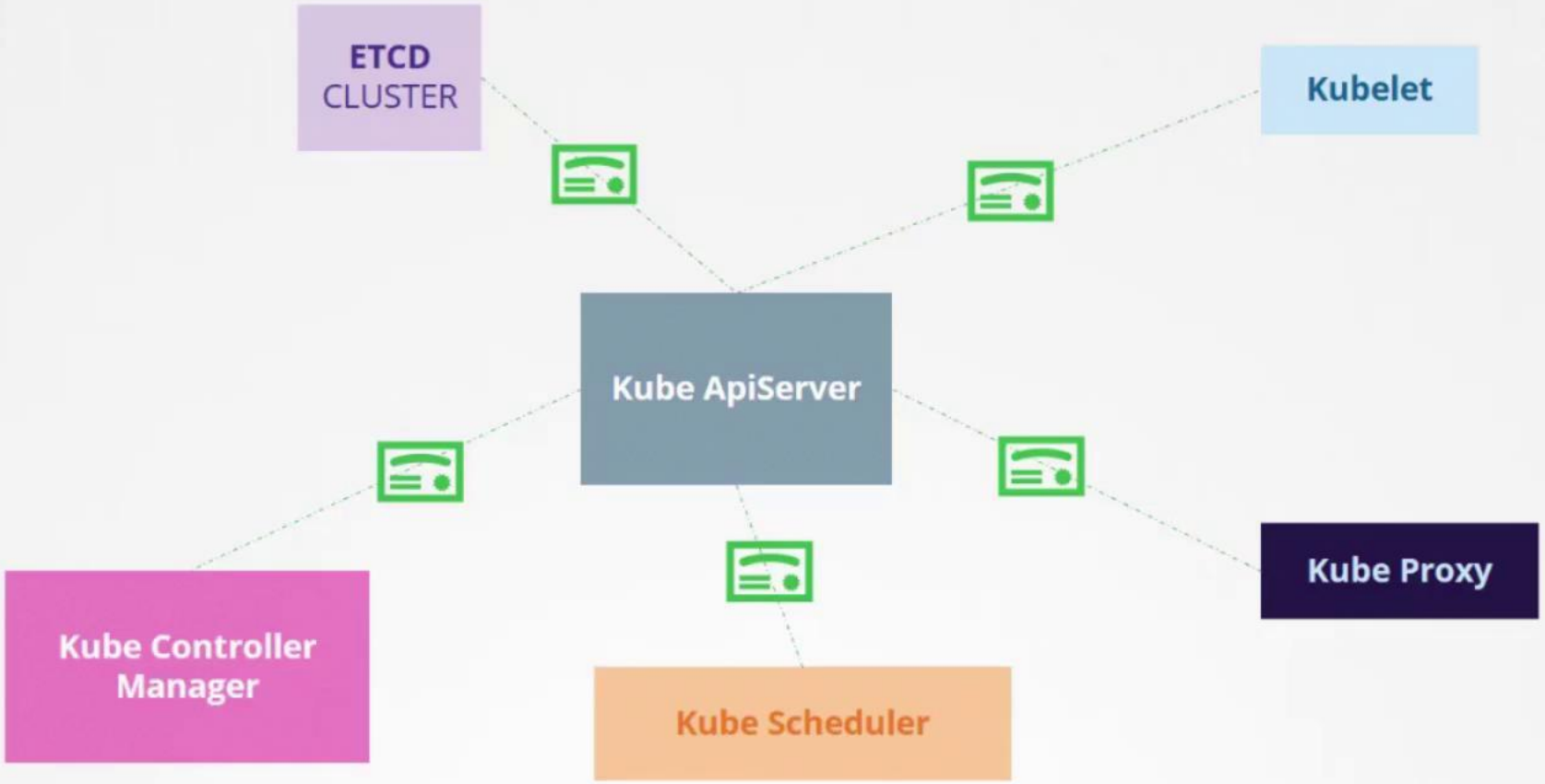
AUTENTICACION

- Kubernetes ofrece diversos mecanismos de autenticación para adaptarse a diferentes necesidades de seguridad:
  - IDs de usuario y contraseñas estáticas
  - Tokens
  - Certificados de cliente
  - Integración con proveedores de autenticación externos (por ejemplo, LDAP)

AUTHORIZATION

- Después de la autenticación, la autorización determina qué acciones puede realizar un usuario o servicio. El mecanismo predeterminado, el Control de Acceso Basado en Roles (RBAC), asocia identidades con permisos específicos. Kubernetes también soporta:
  - Control de Acceso Basado en Atributos (ABAC)
  - Autorización de nodos
  - Autorización basada en webhooks

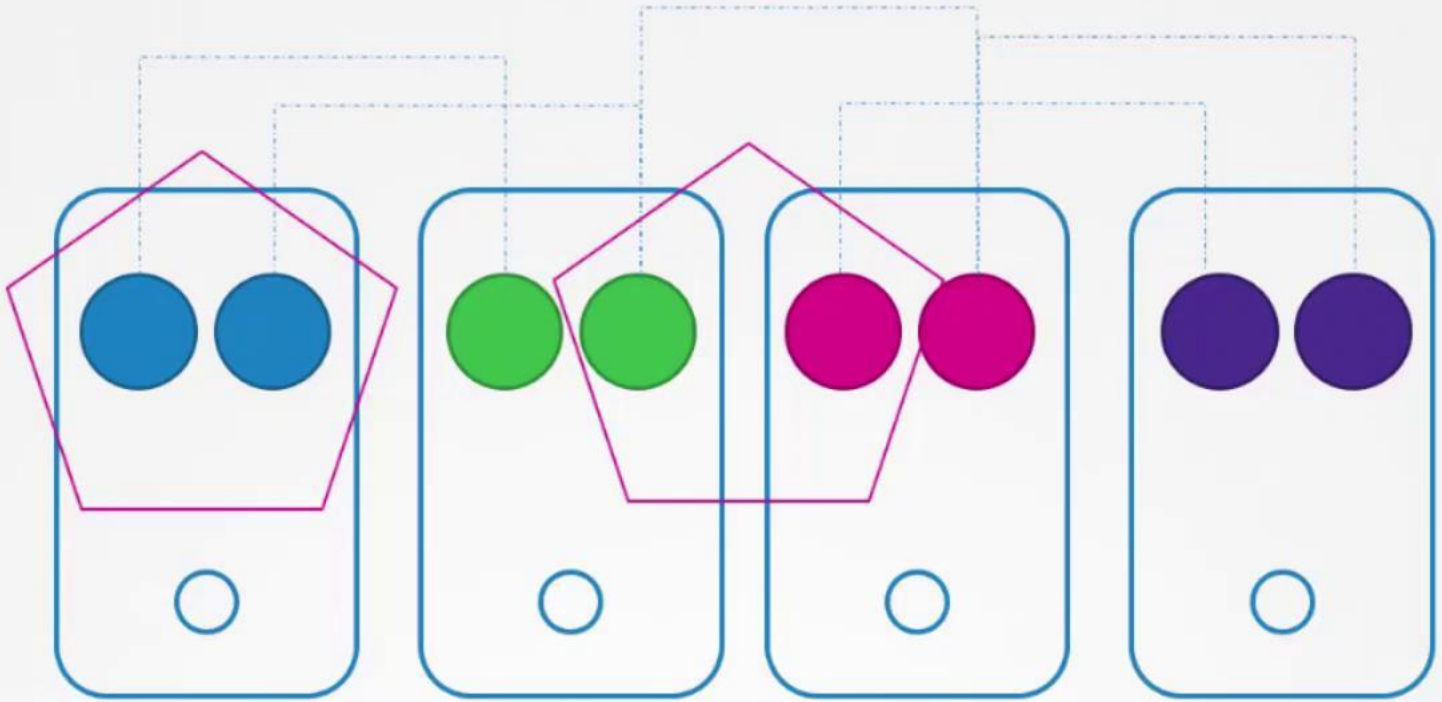
TLS Certificates

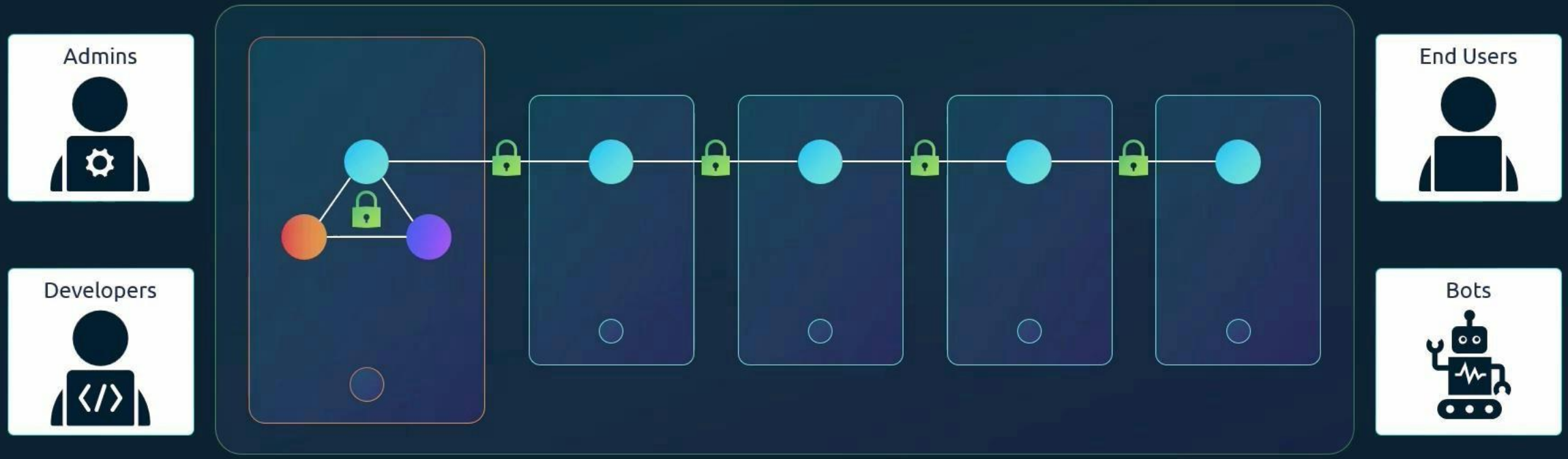


ASEGURANDO LA COMUNICACION ENTRE COMPONENTES

- Las comunicaciones seguras entre los componentes de Kubernetes se habilitan mediante cifrado TLS. Esto garantiza que los datos transmitidos entre los componentes clave se mantengan confidenciales y protegidos contra manipulaciones. El cifrado protege:
  - La comunicación dentro del clúster de etcd
  - Las interacciones entre el Kube Controller Manager y el Kube Scheduler
  - Las conexiones entre los componentes de los nodos de trabajo, como el Kubelet y el Kube Proxy

Network Policies





© Copyright KodeKloud

Auth Mechanisms

kube-apiserver

Static Token File

Certificates

Identity Services

© Copyright KodeKloud

Mechanism	Use case	Example / Notes
Static basic-auth file	Small experiments, local demos	CSV of username/password (plaintext); configured via —basic-auth-file (deprecated)
Static token file	Simple automation, throwaway clusters	CSV mapping bearer tokens to users; configured via —token-auth-file (deprecated)
TLS client certificates	Secure machine access, admin/user certificates	Use CA-signed client certs; verified by kube-apiserver
External identity providers (OIDC, LDAP)	Enterprise SSO, centralized user management	Integrate kube-apiserver with OIDC/LDAP for federated auth

Basic-auth CSV

```
# password,username,uid,groups
KpjCVbI7rCFAHYPkByTIzRb7gu1cUc4B,user10,u0010,group1
rJjncHmvtXHc6MlWQddhtvNyvhgTdxSC,user11,u0011,group1
mjp0FIEiFOKL9toikaRNtt59ePtczZSq,user12,u0012,group2
PG41IXhs7QjqwWkmBkvgGT9g10yUqZij,user13,u0013,group2
```

curl -k -u user10:KpjCVbI7rCFAHYPkByTIzRb7gu1cUc4B https://master-node-ip:6443/api

TOKEN-auth CSV

```
# token,username,uid,groups
c29tZXRva2VuMTIz,user21,u0021,group1
aW5vdGhlcnRva2Vu,user22,u0022,group2
```

curl -k -H "Authorization: Bearer c29tZXRva2VuMTIz" https://master-node-ip:6443/api

User: John
Password: Pass123

User: John
Password: Pass123

http://my-bank.com

ASYMMETRIC ENCRYPTION

Private Key

Public Lock

User: John
Password: Pass123